

Semantic Secrets: Private Authentication from Reconstructable Visual Semantics

Anonymous Author(s)

Abstract

This planning manuscript defines a revised research direction; it does not report a completed system or v2 experiment. We ask whether a remembered visual concept can be reconstructed through independently generated images, converted locally into a canonical typed semantic graph, and privately verified under a system-derived policy. The prompt is a reconstruction interface rather than the secret, and generated pixels are transient observations rather than entropy. The intended contributions combine technical reconstruction stability, mandatory-versus-tolerant semantic policy, acceptance-region attacks under finite budgets, and construction-specific private and unlinkable verification. A complete review of 2026 Visual Semantic Authentication (VSA) makes clear that image-independent semantic authentication, canonical visual tokens, object/attribute/count/quadrant rules, and flexible quantity policies are prior art. The prospective privacy contribution must therefore be established relative to VSA, fuzzy/private matching, protected templates, and established cryptographic primitives. Frozen negative P6/P7 evidence from the earlier v1 pipeline is retained only as formative motivation. The next phase is novelty refresh and preregistration, not implementation.

1 Problem and scope

Authentication based on approximate semantic meaning has an unusual tension. Benign reconstructions must vary, yet every tolerated variation enlarges the set an attacker may submit. If a server stores a deterministic semantic verifier, the same structure that permits fuzzy acceptance may reveal semantic content, support offline candidate testing, or link reuse across services. Secure computation may hide the comparison while leaving the accepted region easily enumerable.

We study a prospective client-side pipeline in which a person reconstructs a remembered visual concept using free natural language. A local generator produces a new image, and a local extractor maps that image into a canonical semantic representation. The strongest target sends neither prompt, image, plaintext graph, nor raw embedding to the authentication infrastructure.

No participant study is planned. Researcher-authored concepts and reconstructions can measure only technical semantic reconstruction stability. They cannot establish memorability, recall, usability, preference, or natural credential choice.

2 The prompt and image are not the secret

Let C denote a remembered visual concept and P a free-form reconstruction prompt. Different expressions may aim at the same concept—for example, “a cat beside a red car” and “a feline next to a crimson automobile.” The hypothesis is not exact prompt reproduction. With generator G and randomness r ,

$$I = G(P, r), \quad (1)$$

where I is a transient, independently generated image. Pixels do not contribute password entropy merely because generation is stochastic. A versioned extractor E produces

$$S = E(I). \quad (2)$$

The credential source is the canonical semantics and, operationally, the complete set of candidate semantics the verifier accepts.

This framing differs from treating direct text embeddings or a single generated image as the authentication object. It also creates a falsifiable condition: if independent generation and fresh extraction do not preserve security-relevant structure, the visual reconstruction hypothesis fails.

3 Canonical policy-aware semantics

We provisionally represent S as a typed graph

$$S = (V, E_S, A, C_S), \quad (3)$$

where V contains entities, E_S typed actions/relations, A attributes, and C_S counts and scene/context facts. A deterministic, versioned policy derivation function produces

$$\Pi(S) = (M, T), \quad (4)$$

where M contains mandatory security anchors and T contains secondary facts with bounded tolerance. The primary non-human study will not ask users to nominate M or T . Selection must be frozen from independent semantic rationale, training-only statistics, extractor reliability, attacker-frequency evidence, and protocol compatibility.

A candidate reference functionality has the form

$$\text{Accept}_{\text{ref}} = \text{MandatoryOK}(M, M') \wedge [\text{ToSim}(T, T') \geq \tau], \quad (5)$$

but the exact graph, operators, missing-value rules, and threshold remain to be preregistered. The notation and policy split are not claimed as standalone novelty.

4 Acceptance-region security

For an enrolled state, define the accepted region

$$\mathcal{A}(S, M, T) = \{(S', M', T') : \text{Accept}_{\text{ref}} = 1\}. \quad (6)$$

An attacker succeeds by finding any member, not by recovering the enrolled prompt, image, or exact graph. We distinguish:

- K_0 : generic public knowledge and random candidates;
- K_1 : population or frequency knowledge without target facts;
- K_2 : partial target-specific semantic information;
- K_3 : strong near-secret information.

For strategy Q , budget B , knowledge K_i , and observable view V , the primary quantity is

$$\text{Succ}(Q, B, K_i, V) = \Pr[\exists j \leq B : q_j \in \mathcal{A}(S, M, T)]. \quad (7)$$

The evaluation should report success@1, @5, @10, and @B, guesses to success, duplicate policy, uncertainty, and cost. Random FAR is only one distributional statistic. Frequency, targeted neighbours,

partial knowledge, LLM/VLM/generator assistance, and adaptive semantic search may produce different risk. AI-assisted password guessing is established prior art [9]; this project must contribute a semantic acceptance-region analysis rather than the general idea of using a model to guess.

5 Privacy target

The protected record is abstractly

$$R = \text{Protect}(S, M, T, \text{account}, \text{domain}, \text{version}). \quad (8)$$

A later protocol should reproduce the frozen plaintext decision while revealing no more than its declared output and metadata. Candidate goals are:

- template confidentiality against semantic recovery or accepted-equivalent reconstruction;
- resistance to cheap database-only candidate validation under an exact stolen-record view;
- policy privacy for anchor identities, operators, weights, thresholds, and graph shape;
- unlinkable, domain-separated records and transcripts;
- transcript minimisation, replay/session binding, and explicit adaptive-query leakage;
- containment under named database, server, key/share, collusion, and total-compromise states.

Established fuzzy extractors [3], OPRFs [2], OPAQUE [1], PSI [8], fuzzy PSI/private biometric matching [11], and homomorphic vector matching [6] are candidate foundations, not novel primitives. Raw learned representations are not automatically private; embedding leakage is an explicit concern [10]. Protected-template unlinkability and irreversibility must be attacked rather than inferred from an encoding [4].

Semantic correctness and cryptographic privacy are independent. FAR/FRR do not prove privacy; private computation does not repair an easily guessed acceptance region.

6 Closest work and VSA boundary

VSA [5] is the closest mandatory baseline. It enrolls a reference image, extracts objects, CLIP-derived attributes, quantities, visibility, and 2x2 quadrant location, and lets a user select two or three semantic facts plus quantity operators. Authentication uses an arbitrary satisfying image and an additional password. VSA serialises canonical semantic tokens, evaluates Flexible Range Logic conjunctions, hashes most semantic fields together with the password using SHA-256, and retains quantity/operator metadata separately.

These features remove image-independent visual-semantic authentication, VLM extraction, canonical tokens, object, attribute, count, and quadrant rules, flexible quantity policies, conjunction, and user-selected semantic policy from our novelty space. We require two fair baselines: (i) VSA’s semantic-policy component for functional discrimination and (ii) the full semantic-plus-password hash architecture for security comparison. We must not compare a semantic-only system directly with VSA’s claimed combined semantic-plus-password space as though the credentials were equivalent.

VSA calls its hash binding server-opaque and explicitly weaker than strict zero knowledge. It acknowledges small semantic inputs and fast SHA-256 offline guessing, recommending Argon2id with a user-specific salt. Its COCO-based positive FRR samples are automatically selected from cached detections rather than independently re-inferred. It reports no human study and leaves Semantic Relationship Logic to future work. It does not target private/unlinkable verification.

SemanticLock uses semantically linked image tokens and story structure for graphical authentication [7], further preventing broad “first semantic graphical password” language. The remaining hypothesis is the evaluated combination of independent generative reconstruction, typed visual-semantic graphs, system-derived mandatory/tolerant policy, acceptance-region attacks, and private/domain-separated verification. P8 must test whether broader prior work already subsumes that combination.

7 Research questions

RQ1—Reconstruction. Can independently generated images representing the same intended visual concept produce stable canonical semantic credentials?

RQ2—Policy-aware matching. Can a system-derived $S = (M, T)$ policy preserve legitimate technical reconstruction variation while rejecting security-critical semantic differences?

RQ3—Acceptance-region security. How vulnerable is the induced accepted region under K_0 – K_3 attackers and finite budgets?

RQ4—Template/privacy leakage. What semantics can be inferred from stored records, policies, and authentication transcripts under named compromise views?

RQ5—Private verification. Can the frozen policy be evaluated while hiding the semantic credential and resisting practical database-only validation and cross-domain linkage under stated assumptions?

RQ6—Practicality. What computation, bandwidth, latency, storage, trust, and deployment assumptions are required?

8 Proposed methodology and baselines

The execution order is deliberately staged.

Novelty and preregistration. P8 completes a primary-source novelty refresh and freezes graph tasks, controlled concepts, splits, capability screening, policy derivation, attack budgets, and gate thresholds. It performs no expensive experiment.

Representation before authentication. P9A screens a small preregistered set of extractors on images with known object, attribute, count, action, relation, and context ground truth. P9B then measures independent generative reconstruction across paraphrases, seeds, layouts, justified styles, and selected version drift. Direct text is an ablation, not the target credential path.

Policy and attackers. P10 compares dense similarity, global fuzzy overlap, a feasible VSA-style policy, and the proposed system-derived M/T policy. P11 evaluates the full acceptance region under budgeted attackers before any cryptographic implementation.

Private verification. Only a constructive semantic-security gate permits P12 to define the ideal functionality and compare mature

constructions. Minimal POCs precede selection. The selected protocol is then evaluated for reference correctness, leakage, offline validation, compromise, linkage, and cost.

Baselines. Planned baselines include direct-text processing, dense visual/text similarity, global fuzzy semantic overlap, VSA semantic-policy behaviour, the full VSA binding model where reproducible, plaintext/hash records, and relevant mature private-matching constructions. Any inaccessible or underspecified VSA behaviour will be documented rather than guessed.

9 Decision gates

The gates are: V2-N novelty viability; V2-A visual-semantic reconstruction viability; V2-B policy-aware semantic viability; V2-C acceptance-region security viability; V2-D private-functionality viability; V2-E protocol selection/privacy viability; and V2-F end-to-end evidence/paper story. No later cost may bypass an earlier failure. Valid outcomes include standalone authentication, second factor, policy-constrained credential, measurement/negative contribution, or stop.

10 Formative v1 evidence

The completed P0–P7 programme evaluated a different system, visual-semantic-pipeline-v1. P6’s training-selected weighted matcher had validation FRR 20.8%, targeted-neighbour FAR 75.0%, and random FAR 3.0%; all tested representations failed the original gate. Twelve v1 test families remain sealed. P7 then found no uncertainty-supported material benefit from the tested SD-Turbo/Florence/SigLIP image pathways and removed that image stage from the v1 authentication core.

These are immutable formative negative results, not v2 measurements. They motivate explicit security anchors and independent capability screening but may not tune the v2 policy, representation, data, or gates. The v2 hypothesis requires new identifiers, preregistration, and evidence.

11 Expected contributions and limitations

If all gates pass, C1 would establish technical generative reconstruction behaviour; C2 would establish the measured value of a system-derived typed policy; C3 would characterise the accepted region under realistic finite-budget attackers; and C4 would establish construction-specific private and unlinkable verification. C3/C4 are expected to carry the principal privacy contribution. C5, adaptive semantic verification-oracle leakage, remains optional and will be folded into C3/C4 unless P8 identifies a distinct result.

Major unresolved risks are that independent visual extraction is not stable, M/T adds no value over VSA-style policy, the semantic region is cheaply reachable, the privacy construction is an obvious application of known primitives, policy metadata recreates an offline oracle, or the required trust/cost is impractical. The controlled methodology cannot establish human memorability or usability. A future participant study would require separate ethics, design, and evidence.

12 Conclusion

This blueprint treats visual generation as a testable reconstruction layer, not a source of magical entropy, and treats privacy as a construction-specific property, not a consequence of hashing semantics. The next permitted work is P8 novelty, formalisation, and preregistration. No v2 model, dataset, experiment, or cryptographic prototype is yet authorised.

References

- [1] D. Bourdreux, H. Krawczyk, K. Lewi, and C. A. Wood. 2025. *The OPAQUE Augmented Password-Authenticated Key Exchange (aPAKE) Protocol*. RFC 9807. RFC Editor. <https://www.rfc-editor.org/rfc/rfc9807.html> Informational RFC; CFRG/IRTF consensus document.
- [2] A. Davidson, A. Faz-Hernandez, N. Sullivan, and C. A. Wood. 2023. *Oblivious Pseudorandom Functions (OPRFs) Using Prime-Order Groups*. RFC 9497. RFC Editor. <https://www.rfc-editor.org/rfc/rfc9497.html> Informational RFC; CFRG/IRTF consensus document.
- [3] Yevgeniy Dodis, Rafail Ostrovsky, Leonid Reyzin, and Adam Smith. 2008. Fuzzy Extractors: How to Generate Strong Keys from Biometrics and Other Noisy Data. *SIAM J. Comput.* 38, 1 (2008), 97–139. <https://www.cs.bu.edu/~reyzin/fuzzy.html>
- [4] Marta Gomez-Barrero, Christian Rathgeb, Javier Galbally, Christoph Busch, and Julian Fierrez. 2016. Unlinkable and Irreversible Biometric Template Protection Based on Bloom Filters. *Information Sciences* 370–371 (2016), 18–32. doi:10.1016/j.ins.2016.06.046
- [5] Pil-seong Jeong. 2026. Design and Security Validation of Image-Agnostic Visual Semantic Authentication (VSA) Framework Based on Vision-Language Model. *Journal of The Korea Institute of Information Security and Cryptology* 36, 3 (June 2026), 935–948. doi:10.13089/JKIISC.2026.36.3.935 Peer-reviewed article in Korean.
- [6] Sam Martin, Nirajan Koirala, Helena Berens, Thomas Rozgonyi, Micah Brody, and Taeho Jung. 2025. HyDia: FHE-based Facial Matching with Hybrid Approximations and Diagonalization. *Proceedings on Privacy Enhancing Technologies* 2025, 4 (2025), 585–604. doi:10.56553/popets-2025-0146
- [7] Ilesanmi Olade, Hai-Ning Liang, and Charles Fleming. 2023. Story-Based Authentication for Mobile Devices Using Semantically-Linked Images. *International Journal of Human-Computer Studies* 171 (March 2023), 102967. doi:10.1016/j.ijhcs.2022.102967
- [8] Benny Pinkas, Thomas Schneider, Gil Segev, and Michael Zohner. 2015. Phasing: Private Set Intersection Using Permutation-Based Hashing. In *24th USENIX Security Symposium (USENIX Security 15)*. USENIX Association, Washington, DC, 515–530. <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/pinkas>
- [9] Javier Rando, Fernando Perez-Cruz, and Briland Hitaj. 2023. PassGPT: Password Modeling and (Guided) Generation with Large Language Models. In *Computer Security – ESORICS 2023 (Lecture Notes in Computer Science, Vol. 14347)*. Springer, 164–183. doi:10.1007/978-3-031-51482-1_9
- [10] Congzheng Song and Ananth Raghunathan. 2020. Information Leakage in Embedding Models. In *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security*. Association for Computing Machinery, 377–390. doi:10.1145/3372297.3417270
- [11] Erkam Uzun, Simon P. Chung, Vladimir Kolesnikov, Alexandra Boldyreva, and Wenke Lee. 2021. Fuzzy Labeled Private Set Intersection with Applications to Private Real-Time Biometric Search. In *30th USENIX Security Symposium (USENIX Security 21)*. USENIX Association, 911–928. <https://www.usenix.org/conference/usenixsecurity21/presentation/uzun>